

Identity and Access Management

Introduction

Identity Access Management (IAM) is a framework of business process, policies and technologies that facilitates the management of electronic or digital identities. Allows IT managers to control user access to critical information within their organizations.

The room covered the following concepts and processes; ***Identification, authentication, Strong passwords and Multi-Factor Authentication (MFA), Authorization & Access control and logging & Auditing.***

Prerequisites

- To finish the *security principles* room.

Objectives

- To understand Identification.
- To gain solid understanding of Authentication
- To understand Authorization
- To understand Accountability
- To understand the Access Control Models
- To understand Sign -On

Methodology

Task 1

The task covered pillars of information, **IAAA Model**; Identification, Authentication, Authorization, and Accountability.

The shot below provided a discuss of the four stages of IAAA models.

1. **Identification** is the process of verifying who the user is. It starts with the user claiming a specific identity. The identity can be represented by a unique identifier such as an email address, a username, or an ID number. Any identifier unique in the respective environment is a valid option; hence, many websites would rely on an email address for identification instead of asking the user to create a unique username.
2. **Authentication** is the process of ensuring that the user is who they claim to be. In other words, this step is about confirming the claimed identity. One way to authenticate would be by providing the correct password. Because of potential password weaknesses, many other methods, such as asking users to type the code sent to their email, are gaining popularity.
3. **Authorisation** determines what the user is allowed to access. In other words, they will be authorised to carry out specific operations based on their account privileges. This process is typically done by assigning roles and permissions based on the user's job function or level of clearance. The risk of unauthorised access or data breaches is reduced by restricting access to only the resources necessary for the user to perform their duties.
4. **Accountability** tracks user activity to ensure they are responsible for their actions. After a user is granted access to a system, it is essential to have mechanisms that hold everyone accountable for their actions. This process is achieved by logging all user activity and storing it in a centralised location. In the event of a security incident, this information can be used to identify the source of the problem and take appropriate action.

The discussed IAAA models were essential in answering the questions below

Answer the questions below

You are granted access to read and send an email. What is the name of this process?

Authorisation

✓ Correct Answer

Which process would require you to enter your username?

Identification

✓ Correct Answer

Although you have write access, you should only make changes if necessary for the task. Which process is required to enforce this policy?

Accountability

✓ Correct Answer

Task 2

Covered Identification in details. This is how a user claims a specific identity. Identification can be through a username, or through a number such as; *National ID number, Student ID, Passport Number, and Mobile phone number.*

The following is an example of usernames for Identification



Which of the following **cannot** be used for identification?

1. Email address
2. Mobile number with international code
3. Year of birth
4. Passport number

3

✓ Correct Answer

Which of the following **cannot** be used for identification?

1. Landline phone number
2. Street number
3. Health insurance card number
4. Student ID number

2

✓ Correct Answer

Task 3

Authentication was covered in this task; it is the process of verifying the identity of a user or system. It differs from identification, where the user claims a specific identity in the respective settings. While Authentication, is proving the identity of the user. It was accomplished through one of the following ways as in the shot below.

1. Something you know
2. Something you have
3. Something you are

The more methods used in a lesser degree are;

- Somewhere you are (logical/physical location)
- Something you do (behaviour)
 - Something you know – one that you have memorized, such as *Passwords*, *Passphrases* and *pin*.
 - *Something you have* – an object, something physical that one has.
 - *Something you are* – biometric readers. Examples include fingerprint readers, facial recognition, retina scanners, and voice recognition.

Multifactor Authentication (MFA)

Covered MFA as a method of using two or more of something you know/ you are/ you have. Purpose for additional security incase one is compromised.

When you want to check your email, you enter your username and password. What kind of authentication is your email provider using?

1

✓ Correct Answer

Your bank lets you finish most of your banking operations using its app. You can log in to your banking app by providing a username and a password and then entering the code received via SMS. What kind of authentication is the banking app using?

4

✓ Correct Answer

Your new landline phone system at home allows callers to leave you a message when the call is not picked up. You can call your home number and enter a secret number to listen to recorded messages. What kind of authentication is being used here?

1

✓ Correct Answer

You have just started working at an advanced research centre. You learned that you need to swipe your card and enter a four-digit PIN whenever you want to use the elevator. Under which group does this authentication fall?

4

✓ Correct Answer

Task 4

The task covered both Authorization and Access Control. Authorization specifies what the authenticated user should be allowed to access and do. While access control, is the selective restriction of access to a place or other computing resources.

Answer the questions below

The new policy states that the secretary should be able to send an email on the manager's behalf. What is this policy dictating?

1

✓ Correct Answer

You shared a document with your colleague and gave them view permissions so they could read without making changes. What would ensure that your file won't be modified?

2

✓ Correct Answer

The hotel management decided that the cleaning staff needed access to all the hotel rooms to do their work. What phase is this decision part of?

1

✓ Correct Answer

Task 5

Covered both Accountability and logging, where Accountability ensures that users are accountable for the actions they perform on a system i.e. after authenticating their identity and getting authorized to access a system, they can be held responsible for their actions.

Logging is the process of recording events that occur within a system. Essential in helping organizations maintain a record of who accessed what information and when. Also helps organizations detect and respond to security incidents.

Log forward is the process of sending log data form one system to another.

Task 6

Dealt with Identity Management (IdM), and Identity and Access Management (IAM). IdM was brought out as an essential component of cybersecurity that refers to the process of managing and controlling digital identities. Its main goal is to ensure that only authorised individuals have access to specific resources and information.

IAM encompasses all the processes and technologies to manage and secure digital identities and access rights. It ensure that only authorized users have access to specific resources and data and that their access is monitored and controlled.

Answer the questions below

What does IdM stand for?

Identity Management

✓ Correct Answer

What does IAM stand for?

Identity and Access Management

✓ Correct Answer

Task 7

The task covered example attacks against a naïve authentication protocol. Authentication is categorized in two; in the analogue world and in the digital world.

In the analogue word, an authentication scheme is essential. A secrete phrase may also be used where one would be required to say a secrete passphrase.

In the digital world, encryption is essentials. User can encrypt a clear password using a selected secret key.

Answer the questions below

The attacker could authenticate using the user's response when the authentication protocol required a password encrypted with a shared key. What is the name of the attack?

Replay Attack

✓ Correct Answer

Task 8

Covered various Access Control Models, which include;

- Discretionary Access Control (DAC) – resource owner explicitly add users with the proper permissions.

Consider the following example. You store your photos on one of the online storage platforms. To share all the images related to your graduation with your family, you add their accounts individually and grant them access to the respective album. Eventually, the album permissions with show a few accounts with view permissions.

The whole process is straightforward and fully controlled by the data owner. It works very well for sharing with family members or a few company users. However, this can get tricky as you try to scale sharing with many users, especially as a user's role changes over time. This situation brings us to sharing based on user roles.

- Role-Based Access Control (RBAC) - Each user has one or more roles or functional positions; furthermore, they are authorized to access different resources based on their roles.
- Mandatory Access Control (MAC) - Prioritize security and significantly limit users' abilities

Answer the questions below

You are sharing a document via a network share and giving edit permission only to the accounting department. What example of access control is this?

2

✓ Correct Answer

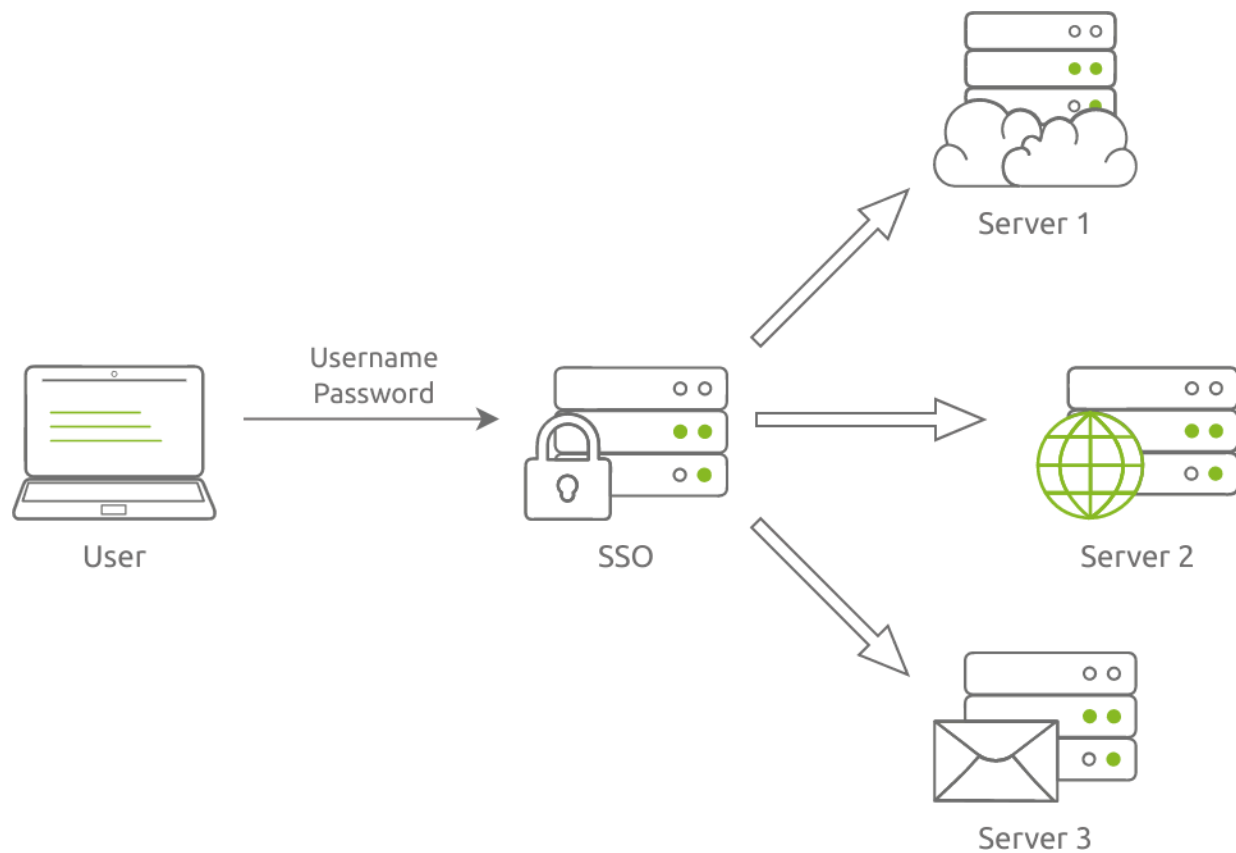
You published a post on a social media platform and made it only visible to three out of your two hundred friends. What kind of access control did you use?

1

✓ Correct Answer

Task 9

Single Sign-On was covered in this task, where it is essential since users don't have to remember multiple usernames and passwords, but only remember a single set of login credentials.



SSO allows organizations to authenticate users once before granting them access to the resources required for their work. We can achieve many advantages from this. Some of the advantages include;

- One strong password: Expecting a user to remember a single strong password is more acceptable than asking them to remember ten different strong passwords.
- Easier MFA: Adding MFA to every different service is a humongous task to accomplish and maintain. With SSO, MFA needs to be enabled and configured once.
- Simpler Support: Support requests like password reset become more straightforward as they are now confined to a single account.
- Efficiency: A user does not need to log in every time they need to access a new service.

What does SSO stand for?

Single Sign-On

✓ Correct Answer

Does SSO simplify MFA use as it needs to be set up once? (Yea/Nay)

Yea

✓ Correct Answer

Is it true that SSO can be cumbersome as it requires the user to remember and input different passwords for the various services? (Yea/Nay)

Nay

✓ Correct Answer

Does SSO allow users to access various services after signing in once? (Yea/Nay)

Yea

✓ Correct Answer

Does the user need to create and remember a single password when using SSO? (Yea/Nay)

Yea

✓ Correct Answer

Task 10

Participated in a timed game of answering questions concerning everything covered in this module.

Room progress (96%)

Task 11 ✓ Scenarios

It is worth repeating that we need to have proper processes in place to help protect the security of the data, systems, and networks. Expressing this in technical terms, protecting the security of a system, for example, means protecting the confidentiality, integrity, and availability of that system. And part of the proper processes required includes appropriate identification, authentication, authorisation, access control, accountability, and logging, among others. Inadequacy in any one process results in the weakening of the security of the respective systems. Securing one process won't replace securing the other processes.

[View Site](#)

Answer the questions below

Click on **View Site** and follow the exercise to get a flag.

[THM_ACCESS_CONTROL] ✓ Correct Answer

Task 12 ○ Conclusion

Try Hack Me

Identification, Authorisation, and Identity Management

Instructions

- Select the option that best describes the text in green. Solve all the questions to get the flag.
- You have 45 seconds to answer all the questions.
- You have 3 attempts and 2 hints.
- Each correct answer will add 10 seconds to the count down, giving you more time to solve the rest of the questions.

Start

IAM Quiz

Conclusion

The room covered the Identity and Access Management in details. Task 1 one of the rooms covered the IAAA model, which comprises of identification, Authorization, Authentication, and Accountability.

Task 2, covered Identification. Which can be inform of usernames, and numbers. Task 3, involved Authentication, a process of ensuring the user is who they claim to be. In task 4, covered Authorisation and Access Control. Task 5, covered Accountability and logging, where Accountability ensures that users are accountable for the actions they perform on a systems and logging, is the process of recording events that occur within a system. Task 6, covered Identity Management (IdM). Task 7, covered the attacks against Authentication, categorized in to two; Digital and Analogue. Task 8, covered the three access models. In task 9, Single Sign-On was covered.

IAM allows managers to control user access to critical information within their organizations.

